Name: Uzair Ali
Reference Code: ARZ-2026-EBPP

Task 1 – Vulnerability Management Lifecycle Playbook

Objective

The Vulnerability Management Lifecycle is a structured process used by organizations to identify, validate, prioritize, remediate, and continuously monitor security vulnerabilities. The objective is to reduce security risks while maintaining the confidentiality, integrity, and availability of organizational assets.

---

1. Intake

The vulnerability management process begins when a security issue is identified through a vulnerability scanner, penetration test, manual assessment, or security monitoring system. All findings are recorded and entered into the organization's vulnerability management process.

Example:
A vulnerability scanner reports that a web server is running an outdated software version.

---

2. Discovery

During the discovery phase, security tools and manual assessments are used to identify potential vulnerabilities within the authorized environment. Common tools include Nmap, Nikto, Burp Suite, Nessus, and OpenVAS.

Lab Activity:
Network reconnaissance and vulnerability identification against the approved lab target.

3. Triage

After vulnerabilities are discovered, each finding is prioritized based on its severity, exploitability, and potential business impact. Findings are typically classified as Critical, High, Medium, Low, or Informational.

Example:
A Remote Code Execution vulnerability receives higher priority than a missing HTTP security header.

---

4. Validation

Not every scanner result represents a real vulnerability. Each finding should be manually validated using version verification, configuration review, or safe testing methods. Findings are categorized as:

- True Positive
- False Positive
- Duplicate
- Needs Further Review

This step helps reduce false alarms and improves reporting accuracy.

---

5. Ownership

Every confirmed vulnerability must be assigned to the appropriate system owner or development team. Ownership ensures accountability throughout the remediation process.

Example:
The Web Development Team is assigned to resolve a missing security header.

---

6. Remediation

The assigned owner applies the appropriate security fix. Remediation may include:

- Installing security patches
- Updating software versions

- Correcting system configurations
- Disabling unnecessary services
- Implementing secure coding practices

---

7. Exception Management

In some situations, immediate remediation may not be possible because of operational, technical, or business constraints. These vulnerabilities are formally documented, and management may temporarily accept the associated risk until a permanent solution is available.

---

8. Retesting

After remediation has been completed, the security team performs a retest to verify that the vulnerability has been successfully eliminated and that no new security issues have been introduced.

Successful verification results in closing the vulnerability ticket.

Vulnerability Management Lifecycle

Intake
↓
Discovery
↓
Triage
↓
Validation
↓
Ownership
↓
Remediation
↓
Exception Management
↓
Retesting
↓
Closure

Conclusion

The Vulnerability Management Lifecycle provides a systematic approach for identifying, validating, prioritizing, and resolving security vulnerabilities. Following this process helps organizations reduce cyber risk, improve security posture, and ensure continuous protection of critical systems.

TASK 2 – Compare Authenticated vs Unauthenticated Scan

Objective

To understand the difference between scanning a target without credentials (unauthenticated scan) and scanning a target after logging into the system (authenticated scan).

Scan Result

The target Windows 10 virtual machine was scanned using an unauthenticated Nmap service detection scan.

Command Used:
nmap -Pn -sV 192.168.86.134
Result:

- Host was reachable.
- Microsoft Windows operating system detected.
- Port 5357/TCP was open.
- Microsoft HTTPAPI 2.0 service detected.
- Remaining TCP ports were filtered by Windows Firewall.

Observation:

The scan successfully identified externally accessible services without using any credentials. Most ports were protected by the host firewall, reducing the externally visible attack surface.

```
┌──(redhunter㉿kali)-[~]
└─$ nmap -Pn -sV 192.168.86.134
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-31 12:56 -0400
Nmap scan report for 192.168.86.134
Host is up (0.0019s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT     STATE SERVICE VERSION
5357/tcp open  http    Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
MAC Address: 00:0C:29:D7:9A:9C (VMware)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap
.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 24.81 seconds
```

Task 3 – Manual Validation of Candidate Findings

Objective

The objective of this task was to manually validate the findings generated during the unauthenticated vulnerability scan. Each finding was reviewed using available evidence such as service versions, network behavior, and system configuration to determine whether it represented a true security issue or required further investigation.

Validation Methodology

The following validation methods were used:

- Reviewing Nmap service detection results.
- Verifying open ports manually.
- Confirming operating system identification.
- Reviewing Windows Firewall behavior.
- Assessing whether findings represented real security risks or normal system behavior.

Finding: Port 5357 Open

nmap -p5357 192.168.86.134

```
┌──(redhunter㉿kali)-[~]
└─$ nmap -p5357 192.168.86.134
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-31 13:26 -0400
Nmap scan report for 192.168.86.134
Host is up (0.0024s latency).

PORT     STATE SERVICE
5357/tcp open  wsdapi
MAC Address: 00:0C:29:D7:9A:9C (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.89 seconds
```

Finding: Microsoft HTTPAPI 2.0

nmap -sV -p5357 192.168.86.134

```
┌──(redhunter㉿kali)-[~]
└─$ nmap -sV -p5357 192.168.86.134
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-31 13:27 -0400
Nmap scan report for 192.168.86.134
Host is up (0.0022s latency).

PORT     STATE SERVICE VERSION
5357/tcp open  http    Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
MAC Address: 00:0C:29:D7:9A:9C (VMware)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap
.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.35 seconds
```

Finding: Windows Host Reachable

nmap -Pn -sV 192.168.86.134

```
┌──(redhunter㉿kali)-[~]
└─$ nmap -Pn -sV 192.168.86.134
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-31 13:29 -0400
Nmap scan report for 192.168.86.134
Host is up (0.0039s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT     STATE SERVICE VERSION
5357/tcp open  http    Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
MAC Address: 00:0C:29:D7:9A:9C (VMware)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap
.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.77 seconds
```

Validation Table

ID	Candidate Finding	Validation Method	Status	Evidence	Risk Level
1	Host is reachable	Verified using Nmap scan	True Positive	Host responded successfully	Informational
2	Windows OS detected	Verified through Nmap service detection	True Positive	Microsoft Windows identified	Informational
3	Port 5357/TCP open	Confirmed through Nmap port scan	True Positive	Port state: Open	Medium
4	M icrosoft HTTPAPI 2.0 detected	Verified using service version detection	True Positive	Service banner identified	Low
5	Windows Firewall filtering ports	Observed during scan (999 filtered ports)	True Positive	Firewall blocked most ports	Low (Protective Control)
6	Excessive exposed services	Manual review of scan results	False Positive	Only one service exposed	None
7	Remote Desktop exposed	Manual verification	False Positive	Port 3389 not open	None
8	Additional review required	Manual inspection recommended for future authenticated scan	Needs Further Review	Internal configuration unavailable	Unknown

Findings Summary

Out of eight candidate findings:

- True Positives: 5
- False Positives: 2
- Needs Further Review: 1
- Duplicate Findings: 0

Conclusion

The manual validation process confirmed that the Windows target exposed only one network service (TCP 5357 running Microsoft HTTPAPI 2.0). Most network ports were protected by the Windows Firewall, significantly reducing the external attack surface. No evidence of Remote Desktop exposure or excessive public services was identified during the unauthenticated assessment. One finding remains under review because internal system configuration cannot be verified without an authenticated scan.

Task 4 – Remediation Tracker

Objective

The objective of this task is to document the remediation plan for all validated findings. Each confirmed finding is assigned an owner, severity level, proposed remediation, retesting procedure, Service Level Agreement (SLA), and acceptance criteria to ensure that vulnerabilities are properly addressed and verified after remediation.

Finding 1 – TCP Port 5357 Open

The vulnerability assessment identified that TCP Port 5357 was open on the Windows target machine. This finding was classified as **Medium Severity** because the exposed service may increase the attack surface if it is not required. The responsibility for remediation belongs to the **Windows System Administrator**. The recommended action is to disable the Web Services for Devices (WSD) service if it is not required or restrict access using Windows Firewall rules. After implementing the remediation, the system should be rescanned using the following command:

nmap -Pn -p5357 192.168.86.134

The issue should be resolved within **30 days**. The finding will be considered closed when Port 5357 is no longer externally accessible.

Finding 2 – Microsoft HTTPAPI 2.0 Service Detected

The scan detected Microsoft HTTPAPI 2.0 running on the target system. This finding was classified as **Low Severity** because it represents a service exposure rather than a confirmed vulnerability. The **Windows System Administrator** is responsible for reviewing the necessity of this service and ensuring that the operating system remains fully updated with the latest security patches. After remediation, another version detection scan should be performed using Nmap to verify that the service is updated or no longer unnecessarily exposed. The expected remediation timeframe is **30 days**.

Finding 3 – Host Reachability

The target machine responded successfully during host discovery, confirming that it is reachable within the authorized lab environment. This finding is considered **Informational** and does not require remediation because network connectivity is expected during penetration testing. The **Network Administrator** is responsible for maintaining secure connectivity within the lab. Connectivity should be verified after any future network configuration changes.

Finding 4 – Windows Firewall Protection

The Nmap scan reported that **999 TCP ports were filtered**, indicating that Windows Firewall is actively protecting the system by blocking unnecessary inbound connections. This finding is also classified as **Informational** because it represents an effective security control rather than a vulnerability. The **Security Administrator** should continue reviewing and maintaining firewall rules on a regular basis. Periodic Nmap scans should be performed to confirm that unnecessary ports remain filtered and that the firewall continues to provide the required level of protection.

Remediation Summary

Based on the vulnerability assessment, all confirmed findings have been assigned to the appropriate system owners along with recommended remediation actions and verification procedures. Medium-risk findings should be addressed within the defined Service Level Agreement (SLA), while informational findings require continuous monitoring instead of immediate corrective action. After remediation, all findings should be revalidated using the same scanning methodology to ensure that the implemented controls are effective and that the identified issues have been successfully resolved.

Task 5 – Triage Stand-Up Briefing

Objective

The purpose of this briefing is to present the most important validated findings identified during the vulnerability assessment, explain their business impact, and recommend remediation priorities.

Five-Minute Triage Briefing

Good morning. During the authorized vulnerability assessment of the Windows 10 lab target, several findings were identified and manually validated. The following three findings were prioritized based on technical risk, exposure, and business impact.

Finding 1 – TCP Port 5357 Open

This finding was assigned a **Medium severity** rating. The scan confirmed that TCP Port 5357 was externally reachable from the tester machine. The service is associated with Microsoft Web Services on Devices (WSD). Although no exploit was demonstrated, unnecessary exposed services increase the attack surface and may provide additional information to an attacker.

Business Impact: Increased network exposure and unnecessary service accessibility.

Recommended Action: Disable the WSD service if it is not required or restrict access through Windows Firewall rules.

Finding 2 – Microsoft HTTPAPI 2.0 Service Detected

This finding was assigned a **Low severity** rating. Version detection identified Microsoft HTTPAPI 2.0 running on the target system. The finding does not confirm a vulnerability, but outdated or unnecessary services should be reviewed and maintained.

Business Impact: Potential exposure if future vulnerabilities affect the service.

Recommended Action: Keep Windows fully updated and disable services that are not operationally required.

Finding 3 – Host Reachability Confirmed

This finding was classified as "**informational.**" The target host responded successfully during network discovery, confirming connectivity within the authorized lab environment.

Business Impact: Expected behavior within the lab; no immediate security concern.
Recommended Action: Continue monitoring network access and maintain segmentation controls.

Priority Recommendation

Based on the assessment, remediation should be prioritized in the following order:

1. **Port 5357 Open** – Medium
2. **Microsoft HTTPAPI 2.0 Detected** – Low
3. **Host Reachability** – Informational

The highest priority is reducing unnecessary externally exposed services.

Conclusion

The assessment identified a limited external attack surface because Windows Firewall filtered most TCP ports. The primary improvement opportunity is reviewing the

necessity of the exposed WSD/HTTPAPI service and restricting it where possible. No evidence of critical remotely exploitable services was identified during this assessment.